

Compliance Gap Analysis Report

SAMA Cyber Security Framework
Prepared for: Al-Rawabi Finance Company
Generated: 2026-07-29 14:30

Executive Summary

Status	Count	Percentage
Compliant	3	8.3%
Partially Compliant	32	88.9%
Non-Compliant	1	2.8%

Detailed Findings

Control	Domain	Status	Justification	Recommendation
3.1.1 Cyber Security Governance	Cybersecurity Governance and Leadership	Partially Compliant	The company has established an internal IT Security Committee, but it lacks a formal charter, fixed meeting frequency, and a dedicated CISO position. The committee is chaired by the Head of IT, which may not be an independent senior manager from a control function.	Establish a formal cyber security committee charter, define the roles and responsibilities of the committee, and appoint a dedicated CISO position who is an independent senior manager from a control function.
3.1.2 Cyber Security Strategy	Cybersecurity Governance and Leadership	Partially Compliant	The company has a documented Information Security Policy (Excerpt 2) and a network architecture diagram (Excerpt 4) that illustrates logical segmentation of the IT infrastructure, but it lacks a formally defined and approved cyber security strategy, and the policy does not explicitly address the importance and benefits of cyber security, the anticipated future state of cyber security, or the execution of cyber security initiatives and projects.	Develop a formally defined and approved cyber security strategy that aligns with the company's strategic objectives and the Banking Sector's cyber security strategy, and update the Information Security Policy to explicitly address the importance and benefits of cyber security, the anticipated future state of cyber security, and the execution of cyber security initiatives and projects.
3.1.3 Cyber Security Policy	Cybersecurity Governance and Leadership	Partially Compliant	The company's policy addresses the definition, approval, and communication of the cyber security policy, but it lacks a formal review process, detailed security standards, and procedures. Additionally, it does not explicitly mention best practices and international standards.	Develop a formal review process for the cyber security policy, define and document detailed security standards and procedures, and ensure that the policy is based on best practices and international standards.

Control	Domain	Status	Justification	Recommendation
3.1.4 Cyber Security Roles and Responsibilities	Cybersecurity Governance and Leadership	Partially Compliant	The company has established an internal IT Security Committee, but it lacks a formal charter, fixed meeting frequency, and a dedicated CISO position. The Board of Directors is not explicitly mentioned as having ultimate responsibility for cyber security.	Establish a formal IT Security Committee charter, define a fixed meeting frequency, and appoint a dedicated CISO to oversee cyber security responsibilities.
3.1.5 Cyber Security in Project Management	Cybersecurity Governance and Leadership	Partially Compliant	The company's policy addresses some aspects of integrating cyber security into project management, such as including cyber security objectives in project objectives (Excerpt 2, Section 1) and having a risk management process (Excerpt 2, Section 3). However, it lacks formalization and details, such as a risk assessment at the start of the project, registering cyber security risks in the project-risk register, and defining responsibilities for cyber security.	Develop a formal project management methodology that includes a risk assessment at the start of each project, registers cyber security risks in the project-risk register, and defines responsibilities for cyber security.
3.1.6 Cyber Security Awareness	Cybersecurity Governance and Leadership	Partially Compliant	The company has a one-time security awareness briefing for new employees, but there is no recurring annual training program, and no specialized technical training is provided to IT staff on cyber security topics. Additionally, the company does not have a formally documented cyber security awareness program for third parties and customers.	Develop a recurring annual training program for all employees and provide specialized technical training to IT staff on cyber security topics. Also, establish a formally documented cyber security awareness program for third parties and customers.
3.1.7 Cyber Security Training	Cybersecurity Governance and Leadership	Partially Compliant	The company provides a one-time security awareness briefing during onboarding, but lacks a recurring annual training program and specialized technical training for IT staff on cyber security topics, as required by the control.	Implement a recurring annual training program and provide specialized technical training for IT staff on cyber security topics to ensure staff are equipped with the skills and required knowledge to protect the company's information assets.
3.2.1 Cyber Security Risk Management	Cyber Security Risk Management and Compliance	Partially Compliant	The company has an informal IT Security Committee, but lacks a formal, documented cyber security risk management process, risk register, risk appetite statement, or periodic risk assessment schedule. The IT Manager makes risk-related decisions on a case-by-case basis.	Establish a formal, documented cyber security risk management process, including a risk register, risk appetite statement, and periodic risk assessment schedule, and ensure that risk-related decisions are made through a structured process.

Control	Domain	Status	Justification	Recommendation
3.2.1.1 Cyber Security Risk Identification	Cyber Security Risk Management and Compliance	Partially Compliant	The company has a network architecture diagram that illustrates the logical segmentation of their IT infrastructure, but it does not explicitly address the identification of cyber security risks. Additionally, the company has a risk management process that is informal and lacks a structured risk register, risk appetite statement, or periodic risk assessment schedule.	Develop a formal, documented cyber security risk management process that includes a structured risk register, risk appetite statement, and periodic risk assessment schedule to ensure comprehensive cyber security risk identification.
3.2.1.2 Cyber Security Risk Analysis	Cyber Security Risk Management and Compliance	Partially Compliant	The company has a risk management process, but it is informal and lacks a structured risk register, risk appetite statement, or periodic risk assessment schedule. This is in line with the control's requirement for a cyber security risk analysis, but the informal nature of the process and lack of formalization make it only partially compliant.	Establish a formal, documented cyber security risk management process with a structured risk register, risk appetite statement, and periodic risk assessment schedule to ensure comprehensive risk analysis and management.
3.2.1.3 Cyber Security Risk Response	Cyber Security Risk Management and Compliance	Partially Compliant	The company has a risk management process, but it is informal and lacks a structured risk register, risk appetite statement, or periodic risk assessment schedule. The excerpts do not address the formal documentation of risk treatment options or the approval and sign-off by the business owner.	Develop a formal, documented cyber security risk management process that includes a structured risk register, risk appetite statement, and periodic risk assessment schedule. Ensure that risk treatment options are documented and approved by the business owner.
3.2.1.4 Cyber Risk Monitoring and Review	Cyber Security Risk Management and Compliance	Partially Compliant	The company has a formal IT Security Committee (Excerpt 3) and a documented Information Security Policy (Excerpt 2), but it lacks a formal, documented cyber security risk management process and a structured risk register, risk appetite statement, or periodic risk assessment schedule (Excerpts 2 and 3).	Establish a formal, documented cyber security risk management process, including a structured risk register, risk appetite statement, and periodic risk assessment schedule, to ensure effective monitoring and review of cyber security risk treatment.
3.2.2 Regulatory Compliance	Cyber Security Risk Management and Compliance	Partially Compliant	The company has established an internal IT Security Committee (Excerpt 1) and reviews its Information Security Policy annually (Excerpt 1), but it lacks a formal, documented cyber security risk management process (Excerpt 1) and a process for ensuring compliance with regulatory requirements affecting cyber security (Excerpt 1 does not explicitly mention this).	Establish a formal, documented cyber security risk management process and a process for ensuring compliance with regulatory requirements affecting cyber security, and ensure that these processes are performed periodically or when new regulatory requirements become effective, involve representatives from key areas, and result in the update of cyber security policy, standards, and procedures.

Control	Domain	Status	Justification	Recommendation
3.2.3 Compliance with (inter)national industry standards	Cyber Security Risk Management and Compliance	Partially Compliant	The company's policy mentions compliance with international industry standards, but it does not specifically mention PCI-DSS, EMV, or SWIFT Customer Security Controls Framework – March 2017. However, it does mention compliance with AES-256 encryption and TLS 1.2 or higher for customer data encryption.	The company should formally document and approve compliance with PCI-DSS, EMV, and SWIFT Customer Security Controls Framework – March 2017, and ensure that all relevant systems and processes are aligned with these standards.
3.2.4 Cyber Security Review	Cyber Security Risk Management and Compliance	Partially Compliant	The company has an informal IT Security Committee and performs annual review of the Information Security Policy, but lacks formal cyber security reviews for critical information assets and penetration tests for customer and internet-facing services.	Establish a formal, documented cyber security review process that includes periodic reviews for critical information assets, penetration tests for customer and internet-facing services, and follow-up reviews to ensure identified issues are addressed.
3.2.5 Cyber Security Audits	Cyber Security Risk Management and Compliance	Partially Compliant	The company has a formal audit manual and audit plan, but it is not explicitly stated that cyber security audits are performed independently and according to generally accepted auditing standards and SAMA cyber security framework. Additionally, the company does not have a formal, documented cyber security risk management process.	Establish a formal, documented cyber security risk management process and ensure that cyber security audits are performed independently and according to generally accepted auditing standards and SAMA cyber security framework.
3.3.1 Human Resources	Cyber Security Operations and Technology	Partially Compliant	The company has defined cyber security responsibilities within staff agreements (Excerpt 3, Section 4. Human Resources and Awareness) and includes staff receiving cyber security awareness at the start of their employment (Excerpt 2, Section 4. Human Resources and Awareness). However, the excerpts do not mention screening and background checks, post-employment cyber security activities, or the monitoring and evaluation of the human resources process.	Develop a formal process for screening and background checks, and define post-employment cyber security activities, such as revoking access rights and returning information assets assigned, to ensure compliance with SAMA CSF Control 3.3.1.
3.3.2 Physical Security	Cyber Security Operations and Technology	Compliant	The company has defined, approved, and implemented a physical security process, including badge-based access control, CCTV coverage, and visitor sign-in logs, as shown in Excerpts 1 and 3. This meets the requirements of the control.	-

Control	Domain	Status	Justification	Recommendation
3.3.3 Asset Management	Cyber Security Operations and Technology	Partially Compliant	The company has a network architecture diagram that shows logical segmentation of the IT infrastructure, but it does not explicitly mention a unified asset register or ownership and custodianship of information assets. Additionally, the asset management process is not defined, approved, or implemented.	Develop and implement a formal asset management process that includes a unified register, ownership and custodianship of information assets, and information asset classification, labeling, and handling.
3.3.4 Cyber Security Architecture	Cyber Security Operations and Technology	Partially Compliant	The company has a defined cyber security architecture (network diagram) and includes some design principles (network segmentation, defense-in-depth), but it lacks formal approval, periodic review, and specific requirements for qualified cyber security architects.	Formalize the cyber security architecture by obtaining approval from the relevant stakeholders, establishing a periodic review process, and defining the qualifications and responsibilities of cyber security architects.
3.3.5 Identity and Access Management	Cyber Security Operations and Technology	Partially Compliant	The company's identity and access management policy is partially addressed, as it requires multi-factor authentication for access to email, VPN, and core banking systems, and access rights are reviewed by the IT Manager on a quarterly basis. However, the policy does not explicitly address user access management for third parties, changes in access rights, or the centralization of the identity and access management function.	Formalize the identity and access management policy to include user access management for third parties, changes in access rights, and the centralization of the identity and access management function, and ensure that these requirements are implemented and monitored.
3.3.6 Application Security	Cyber Security Operations and Technology	Partially Compliant	The company has defined and implemented some application security standards, such as multi-factor authentication and encryption, but lacks formal documentation and periodic evaluation of these controls.	Develop a formal, documented application security standard that includes secure coding standards, segregation of duties, data protection, vulnerability and patch management, and periodic cyber security compliance review, and establish a process for monitoring and evaluating the effectiveness of these controls.
3.3.7 Change Management	Cyber Security Operations and Technology	Partially Compliant	The company has a change management process in place, but it lacks formalization and specific requirements such as security testing, approval from the cyber security function, and post-implementation review of related cyber security controls.	Formalize the change management process by defining and documenting specific requirements, including security testing, approval from the cyber security function, and post-implementation review of related cyber security controls.
3.3.8 Infrastructure Security	Cyber Security Operations and Technology	Partially Compliant	The company's policy addresses some aspects of infrastructure security, such as network segmentation, defense-in-depth, and disaster recovery, but it lacks formal documentation of infrastructure security standards, segregation of duties, and periodic evaluation of effectiveness.	Formally document infrastructure security standards, establish a segregation of duties matrix, and implement a periodic evaluation process to assess the effectiveness of infrastructure security controls.

Control	Domain	Status	Justification	Recommendation
3.3.9 Cryptography	Cyber Security Operations and Technology	Compliant	The company has defined a cryptographic security standard (AES-256 for data at rest and TLS 1.2 or higher for data in transit), approved it through the core banking vendor's built-in key management module, and implemented it.	-
3.3.10 Bring Your Own Device (BYOD)	Cyber Security Operations and Technology	Partially Compliant	The company has a defined, approved, and implemented BYOD cyber security standard (albeit not explicitly stated in the excerpts), but it lacks formalization and specific details such as user responsibilities, restrictions, and consequences, as well as the regulation of corporate mobile applications.	Develop a formal BYOD policy document that outlines user responsibilities, restrictions, and consequences, as well as the regulation of corporate mobile applications, and ensure that it is approved, documented, and communicated to all employees.
3.3.11 Secure Disposal of Information Assets	Cyber Security Operations and Technology	Partially Compliant	The company has a physical security policy that includes secure disposal of information assets, but it does not explicitly mention secure disposal standards and procedures, nor does it address the monitoring of compliance with these standards and procedures.	Develop and document a secure disposal standard and procedure, and implement a monitoring process to ensure compliance with these standards and procedures.
3.3.12 Payment Systems	Cyber Security Operations and Technology	Partially Compliant	The company has a network architecture diagram that shows logical segmentation of the IT infrastructure, including internet-facing services, internal core systems, remote access, and disaster recovery. However, it does not explicitly define, approve, implement, and monitor a cyber security standard for payment systems as required by the control.	Develop a formal cyber security standard for payment systems, including procedures for defining, approving, implementing, and monitoring, and ensure it is reviewed and updated periodically.
3.3.13 Electronic Banking Services	Cyber Security Operations and Technology	Compliant	The company's policy addresses the use of multi-factor authentication (MFA) for access to email, VPN, and core banking systems, and also shows that MFA is enforced through a Conditional Access Policy in Azure AD.	-
3.3.14 Cyber Security Event Management	Cyber Security Operations and Technology	Partially Compliant	The company has a security event management process defined, approved, and implemented (Excerpt 1), but it lacks a formal, documented incident response plan, no defined incident severity classification, and no dedicated incident response team (Excerpt 2).	Establish a formally documented incident response plan, define incident severity classification, and designate a dedicated incident response team to handle security incidents.

Control	Domain	Status	Justification	Recommendation
3.3.15 Cyber Security Incident Management	Cyber Security Operations and Technology	Partially Compliant	The company has a process for reporting suspected security incidents, but it lacks a formally documented incident response plan, incident severity classification, and a dedicated incident response team. The company also has a network architecture diagram that shows logical segmentation of the IT infrastructure, but it does not explicitly address the requirements for a restricted area for CERT workspaces or a cyber security incident repository.	Develop a formally documented incident response plan, establish a dedicated incident response team, and implement a system for incident severity classification. Additionally, consider implementing a restricted area for CERT workspaces and a cyber security incident repository to store incident-related information.
3.3.16 Threat Management	Cyber Security Operations and Technology	Partially Compliant	The company has a network architecture diagram that shows logical segmentation of the IT infrastructure, but it does not explicitly mention the use of internal sources such as access control, application and infrastructure logs, IDS, IPS, security tooling, SIEM, and support functions. Additionally, the excerpts do not provide a defined methodology to analyze threat information periodically.	Develop a formal threat intelligence management process that includes the use of internal sources and a defined methodology to analyze threat information periodically, and document it in the security policy.
3.3.17 Vulnerability Management	Cyber Security Operations and Technology	Partially Compliant	The company has a network diagram that shows logical segmentation of the IT infrastructure, but it does not explicitly mention a vulnerability management process or frequency of performing vulnerability scans. Additionally, the policy mentions multi-factor authentication, but it does not address the classification of vulnerabilities, defined timelines to mitigate, or prioritization for classified information assets.	Develop a formal vulnerability management process that includes regular vulnerability scans, classification of vulnerabilities, defined timelines to mitigate, and prioritization for classified information assets, and ensure that this process is documented, approved, and implemented.
3.4.1 Contract and Vendor Management	Third Party Cyber Security	Partially Compliant	The company has a non-disclosure agreement for vendors, but no formal security risk assessment or security questionnaire is performed on vendors before or during engagement. The company also has a network diagram showing logical segmentation, but it does not explicitly address the requirements for contract and vendor management processes.	Develop a formal security risk assessment and security questionnaire for vendors, and include it in the contract management process. Also, ensure that the network diagram is updated to include specific requirements for contract and vendor management processes.
3.4.2 Outsourcing	Third Party Cyber Security	Partially Compliant	The company has defined some cyber security requirements within their outsourcing policy and process, but they are not formally documented or approved. The effectiveness of these controls is not periodically measured and evaluated.	Formally document and approve the cyber security requirements within the outsourcing policy and process, and establish a regular evaluation schedule to measure their effectiveness.

Control	Domain	Status	Justification	Recommendation
3.4.3 Cloud Computing	Third Party Cyber Security	Non-Compliant	The excerpts do not address the requirements for cloud computing policy for hybrid and public cloud services, including the process for adopting cloud services, data location, data use limitations, security, data segregation, business continuity, audit, review and monitoring, and exit.	Develop and document a cloud computing policy that addresses all the requirements mentioned in SAMA CSF Control 3.4.3, including the process for adopting cloud services, data location, data use limitations, security, data segregation, business continuity, audit, review and monitoring, and exit.